UNIT 5 · TOPIC 5.1

Application and Data Vulnerabilities and Attacks

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A web application builds its database queries by directly concatenating user-supplied search terms without any validation. Which attack does this coding practice most directly enable?

- **● A. SQL injection**
- ○ B. Cross-site request forgery (CSRF)
- ○ C. Distributed denial-of-service (DDoS)
- ○ D. ARP spoofing

Correct answer: A

Why: Concatenating unvalidated user input into SQL queries allows an attacker to alter the query's logic, a SQL injection attack. Input sanitization and parameterized queries are the standard mitigations. CSRF, DDoS, and ARP spoofing exploit different mechanisms (session tokens, bandwidth, and link-layer resolution respectively) and are not caused by unvalidated SQL input.

*Why the others are wrong: **B**, CSRF exploits a user's authenticated session to make unauthorized requests, it is unrelated to server-side query construction. **C**, DDoS attacks overwhelm server resources with traffic volume; they are not caused by query-building logic. **D**, ARP spoofing is a network-layer attack on MAC-to-IP mapping and has no connection to application query handling.*

2. When evaluating the risk of an application vulnerability, "likelihood" refers to which of the following?

- **● A. The probability that an attacker will discover and exploit the vulnerability**
- ○ B. The severity of data loss if the vulnerability is successfully exploited
- ○ C. The number of user records stored in the affected database
- ○ D. The time required to develop and deploy a patch

Correct answer: A

Why: Likelihood is the probability of a threat event occurring, how probable it is that an attacker will find and exploit a given vulnerability. Impact (choice B) is the other axis of risk evaluation. Record count (C) and patch time (D) may influence impact or remediation priority but are not the definition of likelihood.

*Why the others are wrong: **B**, This describes impact, not likelihood, a common confusion because both are components of overall risk. **C**, Record count relates to the scale of potential impact (how many people are affected), not the probability of an attack. **D**, Patch deployment time is a remediation factor, not part of the likelihood assessment.*

3. A web application displays detailed database error messages to users whenever a query fails. Which risk does this behavior most directly create?

- ○ A. It increases the application's availability by surfacing server-side diagnostics.
- **● B. It provides attackers with schema details and query structure useful for crafting injection attacks.**
- ○ C. It reduces the need for user authentication.
- ○ D. It automatically encrypts sensitive data sent to the browser.

Correct answer: B

Why: Verbose error messages often include table names, column names, and query fragments, exactly the reconnaissance information an attacker needs to craft a targeted injection payload. Production applications should suppress detailed errors and log them server-side only. The remaining choices do not describe consequences of error verbosity.

*Why the others are wrong: **A**, Surfacing raw database errors to end users is a security anti-pattern, not an availability feature. **C**, Authentication requirements are independent of error message verbosity. **D**, Error message display has no effect on transport encryption (TLS/HTTPS).*

4. A healthcare portal stores patient records in a backend database and builds SQL queries by concatenating unvalidated user search terms. Which statement best explains why this represents a high-impact risk?

- **● A. An attacker could craft input to extract, modify, or delete protected health records, threatening confidentiality, integrity, and potentially availability.**
- ○ B. Unvalidated SQL queries consume excessive server resources, degrading performance for all users.
- ○ C. Unvalidated input increases database storage size, creating an availability risk.
- ○ D. The absence of input validation prevents the application from generating audit logs.

Correct answer: A

Why: SQL injection in a healthcare context creates a high-impact risk because an attacker can bypass authentication, exfiltrate patient records (HIPAA-regulated data), alter diagnoses or treatment histories, or drop tables, violating all three CIA triad properties. Performance degradation (B), storage growth (C), and logging issues (D) are either incorrect or negligible compared to direct data compromise.

*Why the others are wrong: **B**, Query concatenation does not inherently increase resource consumption; this choice conflates poor coding style with a DoS condition. **C**, Injection attacks alter query logic, not database storage size, this is a misapplication of the vulnerability's mechanism. **D**, Audit logging is a separate application component; its availability does not depend on input validation.*

5. An analyst rates a path traversal vulnerability as high likelihood because the application is publicly accessible and the vulnerability class appears in the OWASP Top 10. Which factor most directly justifies this likelihood rating?

- ○ A. The number of files stored in the application's upload directory
- ○ B. The sensitivity classification of data that could be accessed if exploited
- **● C. The broad internet exposure of the application combined with documented, widely available exploitation techniques for this vulnerability class**
- ○ D. The absence of multi-factor authentication on administrator accounts

Correct answer: C

Why: Likelihood is driven by attacker opportunity and capability. A publicly accessible application expands the attacker pool to anyone on the internet; OWASP Top 10 inclusion confirms that exploitation techniques are well-known and tooled. Together, these factors make exploitation probable. File count (A) and data sensitivity (B) relate to impact. MFA gaps (D) affect authentication bypass, not path traversal likelihood directly.

*Why the others are wrong: **A**, The number of files affects the scope of what could be exfiltrated, an impact factor, not a likelihood factor. **B**, Data sensitivity drives impact severity; it does not change how probable exploitation is. **D**, Missing MFA increases the risk of credential-based attacks, not path traversal, which bypasses file access controls rather than authentication.*

6. A stored cross-site scripting (XSS) vulnerability allows an attacker to inject malicious scripts into a comment field. Other users who load the page containing that comment have the attacker's script execute in their browsers. How does this attack exploit the application vulnerability?

- ○ A. It overflows the web server's memory, causing the application to crash and become unavailable.
- ○ B. It intercepts encrypted network packets between users and the server to extract session tokens.
- ○ C. It escalates the attacker's privileges directly on the server by modifying configuration files.
- **● D. It uses the application as a persistent delivery mechanism, injecting code that executes in victims' browsers whenever they view the compromised content.**

Correct answer: D

Why: Stored XSS exploits an application's failure to sanitize output when rendering user-supplied content. The injected script is saved server-side and served to every user who views the affected page, executing in their browser context, where it can steal session cookies, perform actions on the user's behalf, or redirect to malicious sites. The other choices describe memory corruption, network interception, and server-side privilege escalation, none of which match XSS's client-side browser execution model.

*Why the others are wrong: **A**, XSS targets the client's browser, not server memory; buffer overflow is a separate vulnerability class. **B**, Intercepting encrypted traffic describes a man-in-the-middle attack, not XSS, which works without touching the network layer. **C**, XSS executes in the browser's sandbox, not on the server, it cannot directly modify server configuration files.*

7. An e-commerce platform uses a third-party deserialization library to process session tokens. A critical remote code execution (RCE) vulnerability in this library was publicly disclosed 48 hours ago (CVSSv3 score: 9.8). The platform's WAF blocks known exploit signatures, but the vulnerability is too new for comprehensive signature coverage. Evaluating both likelihood and impact, which risk classification is most defensible?

● A. High likelihood, high impact, a critical CVSSv3 score combined with an active disclosure window and signature-incomplete WAF coverage makes exploitation both probable and potentially catastrophic.

○ B. Low likelihood, high impact, WAF mitigation reduces the attack surface sufficiently to lower likelihood despite the critical CVSSv3 score.

○ C. Low likelihood, low impact, RCE via a session library only affects session token processing, not user data or application logic.

○ D. High likelihood, low impact, WAF signature controls cap the maximum achievable damage even if an attacker bypasses initial detection.

Correct answer: A

Why: A CVSSv3 score of 9.8 indicates near-maximum exploitability and impact. The 48-hour disclosure window is the most dangerous period, exploit code often appears on public repositories within hours of CVE publication, before WAF vendors can ship accurate signatures. An RCE vulnerability in session handling can allow arbitrary code execution on the server, potentially compromising all user data, application logic, and downstream systems. A partially effective WAF does not reduce likelihood to low when exploit tooling is actively circulating. Choice B underestimates likelihood; C underestimates both axes; D incorrectly assumes a WAF caps impact against an RCE that may circumvent it entirely.

*Why the others are wrong: **B**, WAF signature-based mitigations are reactive, not proactive, in a zero-day window, attacker techniques frequently outpace signature availability, so likelihood cannot be rated low. **C**, RCE allows arbitrary code execution on the server, not just token manipulation, impact extends to full system compromise, data exfiltration, and lateral movement. **D**, WAF controls do not cap damage from RCE; successful code execution bypasses application-layer controls entirely, allowing the attacker to disable or modify the WAF itself.*

8. A banking application accepts XML input from partner APIs without disabling external entity processing. An independent audit rates this XXE vulnerability as medium likelihood but critical impact, internal network topology could be exposed. A development lead argues the risk should be downgraded because "no partner has reported exploiting it." Which counterargument most accurately challenges this reasoning?

● A. Absence of reported exploitation does not imply absence of exploitation; advanced persistent threat actors rarely announce intrusions, and likelihood must be assessed against attacker capability and motivation, not incident-reporting history alone.

○ B. Partners are contractually obligated to report security incidents, so the absence of reports confirms the vulnerability has not been exploited.

○ C. XXE attacks only expose file contents, not credentials, so impact should be reclassified as low regardless of what network information is accessible.

○ D. WAF rules can reliably detect and block all XXE payload variants, so the risk is acceptable without remediation.

Correct answer: A

Why: Sophisticated attackers, particularly those interested in banking infrastructure, operate stealthily precisely to avoid detection and reporting. Absence of evidence is not evidence of absence. Risk likelihood must be grounded in threat actor capability, known exploitation techniques (XXE is well-documented and tooled), and the value of the target, not in whether victims or partners have self-reported incidents. Contractual reporting obligations (B) do not guarantee detection or disclosure. XXE can expose internal SSRF paths, file contents including configuration files with credentials, and internal service metadata, impact is not limited to literal file reads (C). WAF signatures for XXE are incomplete and bypassable through encoding variations (D).

*Why the others are wrong: **B**, Contractual obligations require reporting known incidents, they cannot compel reporting of undetected intrusions, which are the norm in APT campaigns. **C**, XXE with SSRF chaining can expose internal endpoints, cloud metadata credentials (e.g., AWS IMDSv1), and network topology, the impact scope is substantially broader than file-reading alone. **D**, XXE payloads are trivially obfuscated using XML encoding variants; WAF rules cannot reliably block all forms without also breaking legitimate XML processing.*

9. A penetration test of a SaaS platform reveals two vulnerabilities: (1) an unauthenticated reflected XSS in a rarely visited admin diagnostics page, and (2) an insecure direct object reference (IDOR) in the user profile API that allows any authenticated user to read any other user's billing records. Resources allow patching only one before the next release. Which risk evaluation most defensibly supports prioritizing the IDOR?

○ A. XSS is listed before IDOR in the OWASP Top 10, making XSS inherently higher priority regardless of context.

○ B. The reflected XSS should be prioritized because unauthenticated attack surfaces always present greater inherent risk than authenticated ones.

○ C. IDOR should always be prioritized over XSS because API vulnerabilities are categorically more severe than UI vulnerabilities.

● D. The IDOR presents direct, immediately exploitable data exposure at scale for all authenticated users, whereas the reflected XSS requires attacker-controlled social engineering to reach a low-traffic page, significantly limiting its realistic likelihood.

Correct answer: D

Why: Risk prioritization requires combining likelihood and impact in context, not applying categorical rules. The IDOR is exploitable by any of the platform's authenticated users with no social engineering prerequisite: one API call with a modified object ID exposes billing records for every user in the system, creating both a mass data breach scenario and regulatory exposure (PCI-DSS, GDPR). The reflected XSS on an admin diagnostics page requires constructing a malicious URL and successfully delivering it to an admin who clicks it on a low-traffic page, a lower-probability attack chain. Choice A misapplies OWASP rankings as rigid priority lists; choice C asserts a false categorical rule; choice B incorrectly assumes unauthenticated exposure always outweighs authenticated mass exposure.

*Why the others are wrong: **A**, OWASP Top 10 rankings reflect prevalence and awareness priorities across the industry, not a ranked remediation queue for specific vulnerabilities in a specific context. **B**, The authentication requirement for the IDOR merely limits exploitation to registered users, in a SaaS with many authenticated users, this is a low bar, and the mass-scale billing data exposure outweighs the unauthenticated-but-low-probability XSS chain. **C**, Attack surface classification (API vs UI) does not determine severity, the exploitability and impact of the specific vulnerability in its deployment context does.*

10. A risk register is a structured document used to record cybersecurity risks. Which pair of elements is most essential to include for each entry?

○ A. Employee usernames and their corresponding salary data

● B. Likelihood of occurrence and potential impact

○ C. Application source code version numbers and deployment timestamps

○ D. Network topology diagrams and server hardware specifications

Correct answer: B

Why: A risk register exists to track risks so they can be prioritized and addressed. The two core dimensions of any risk entry are likelihood (how probable is exploitation?) and impact (what are the consequences?). Together they determine risk priority. Employee salaries (A), version numbers (C), and hardware specs (D) are not properties of individual risk entries, they may appear in asset inventories or HR systems but do not constitute risk documentation.

*Why the others are wrong: **A**, Salary data belongs in HR systems, not risk registers, it has no bearing on the probability or severity of a cybersecurity risk. **C**, Source code versions may appear in vulnerability tracking tickets but do not by themselves constitute risk documentation with likelihood and impact assessments. **D**, Network topology documents the infrastructure layout; it is a supporting artifact, not a component of individual risk entries.*

11. Which of the following best describes the purpose of documenting application vulnerabilities in a structured format?

○ A. To replace the need for endpoint antivirus software

● B. To maintain a record of known weaknesses so they can be prioritized, tracked, and remediated

○ C. To satisfy government export control compliance requirements

○ D. To establish legal accountability when a security incident occurs

Correct answer: B

Why: Structured vulnerability documentation creates a shared, prioritized record that allows security teams to allocate remediation resources rationally, track progress, and demonstrate due diligence. It does not replace preventive controls like antivirus (A), satisfy export regulations (C), or serve primarily as legal evidence (D), though it may support audits as a secondary effect.

*Why the others are wrong: **A**, Documentation records vulnerabilities after discovery; antivirus provides real-time threat prevention, these are complementary, not substitutes. **C**, Export control compliance governs the transfer of controlled technology across borders and is unrelated to vulnerability documentation practices. **D**, While documentation may be reviewed after an incident, its primary purpose is proactive risk management, not post-incident legal attribution.*

12. An AI-assisted scanning tool identifies a path traversal vulnerability in a company's web application. What is the analyst's most appropriate next step?

○ A. Immediately take the web application offline and delete its files from the server

○ B. Notify all users that their data has been breached

● C. Document the vulnerability's location, severity, and potential impact in the organization's risk register and assign it to the remediation queue

○ D. Rewrite the entire application from scratch using a different framework

Correct answer: C

Why: Upon discovery, a vulnerability must be documented, capturing its location, severity, potential impact, and recommended remediation, so the organization can track and prioritize the fix. Immediately taking the application offline (A) may be warranted in extreme cases but is a business decision requiring stakeholder input, not a unilateral first action. Notifying users of a breach (B) is premature before confirming whether the vulnerability was exploited. Full rewrites (D) are disproportionate and do not follow standard vulnerability response procedures.

*Why the others are wrong: **A**, Taking an application offline without authorization disrupts legitimate business and should follow incident response procedures, not be the analyst's immediate unilateral action. **B**, A discovered vulnerability is not the same as a confirmed breach, notifying users at this stage would cause unnecessary panic and may violate responsible disclosure practices. **D**, Vulnerability remediation targets the specific flaw (e.g., input validation, access controls), complete framework rewrites are rarely the proportionate or practical response.*

13. An AI-powered DAST tool produces the following finding: "Command injection vulnerability in /api/ping; CVSSv3 8.6; exploitable remotely without authentication." Which additional information must the analyst add to make this a complete, actionable risk documentation entry?

○ A. The name and version of the AI vendor that produced the scan

● B. The affected component, attack vector, CVSSv3 score, recommended mitigation, and an assigned risk owner

○ C. A full inventory of every HTTP endpoint in the application, including those not flagged by the scan

○ D. The organization's complete network diagram and physical asset list

Correct answer: B

Why: Actionable risk documentation must tell the remediation team what is affected, how it can be exploited, how severe it is, what to do about it, and who is responsible. The tool's finding already supplies the component and CVSSv3 score; the analyst must add recommended mitigation (e.g., input sanitization, parameterized commands) and assign an owner to drive remediation. Tool vendor identity (A) is metadata, not risk content. A full endpoint inventory (C) and network diagram (D) are supporting artifacts irrelevant to documenting this specific vulnerability.

*Why the others are wrong: **A**, The scanner's vendor name is administrative metadata; it does not help the remediation team understand, prioritize, or fix the vulnerability. **C**, A full endpoint inventory is a scope document for a security assessment, not a component of a single vulnerability's risk documentation entry. **D**, Network diagrams support architecture reviews and incident response, not individual vulnerability documentation.*

14. During a code review, a developer identifies an insecure deserialization flaw in a Python application that processes untrusted user uploads and logs it as "medium severity, deserialization bug in upload handler." Why is this documentation insufficient for risk management purposes?

● A. The entry omits likelihood of exploitation, potential impact on systems and data, affected assets, and recommended remediation, information necessary for the organization to prioritize and act on the risk.

○ B. Medium severity is always an inappropriate rating for deserialization flaws, which must be rated critical.

○ C. Developers are not authorized to document security risks; documentation authority belongs exclusively to security analysts.

○ D. Vulnerabilities should only be formally documented after exploitation is confirmed, to ensure accuracy of impact data.

Correct answer: A

Why: A risk documentation entry that states only a name and a severity label cannot drive prioritization or remediation. The team needs to know: How likely is it to be exploited? What can an attacker achieve (e.g., arbitrary code execution, data tampering)? Which systems and data are in scope? What is the recommended fix? Without these, the entry is a label rather than a managed risk. Severity rating disputes (B) are secondary to the completeness problem. Role-based documentation restrictions (C) vary by organization but are not a fundamental documentation sufficiency issue. Post-exploitation documentation (D) contradicts the purpose of proactive risk management.

*Why the others are wrong: **B**, Severity must be assessed in context, insecure deserialization can range from low to critical depending on the deserializer, data trust level, and application architecture. **C**, Many organizations encourage or require developers to log vulnerabilities they discover, restricting documentation to security analysts would create bottlenecks and delay risk visibility. **D**, Documenting risks before exploitation is the entire point of proactive vulnerability management; post-exploitation documentation is incident response, not risk management.*

15. An AI scanner flags 47 issues in a newly deployed e-commerce application, ranging from missing security headers to a critical SQL injection flaw. A project manager instructs the security team to document only the issues scheduled for the current sprint. Why does this approach undermine risk management?

● A. Undocumented risks remain invisible to all stakeholders, they cannot be formally accepted, transferred, or tracked, and may be exploited before they are ever acknowledged.

○ B. Documenting fewer issues conserves storage resources, which outweighs any security concern in a sprint-based context.

○ C. Project managers require prior security team approval before any vulnerability documentation decisions can be made.

○ D. AI-generated findings are too unreliable to document without manual confirmation of every individual issue first.

Correct answer: A

Why: Risk management requires that all known risks be formally documented, even if a decision is then made to defer or accept them. An undocumented risk has no owner, no timeline, and no stakeholder visibility, it simply disappears from organizational awareness until it is exploited. Deferring remediation is acceptable; omitting documentation is not. Storage (B) is a trivial concern relative to breach costs. Approval hierarchies (C) may vary but do not justify non-documentation. AI scanners (D) require verification for accuracy but their findings should be logged as preliminary findings pending confirmation, not discarded.

*Why the others are wrong: **B**, The cost of documenting 47 findings is negligible; the cost of an undocumented SQL injection being exploited is not. **C**, Documentation authority governance varies by organization, but deferring documentation entirely is distinct from managing*

approval workflows. ***D****, Industry practice is to document scanner findings as preliminary and flag for verification, not to withhold documentation until every finding is manually confirmed.*

16. A fintech startup uses an AI-powered DAST tool producing weekly reports exported as PDFs to a shared folder. Six months later, a regulator requests evidence that a critical IDOR vulnerability found in month 2 was properly remediated. The security team cannot reconstruct a remediation timeline. Which documentation practice would have most directly prevented this governance gap?

● A. Maintaining a living risk register linking each vulnerability to its discovery date, assigned owner, remediation actions, verification evidence, and formal closure date, updated continuously as findings progress through the remediation lifecycle

○ B. Running DAST scans daily instead of weekly to generate a denser audit trail

○ C. Storing PDF reports in a version-controlled repository to preserve scan history

○ D. Restricting formal documentation to findings with CVSSv3 scores above 7.0 to reduce administrative overhead

Correct answer: A

Why: The regulator's request requires demonstrating not just that a vulnerability existed, but that it was owned, actioned, verified, and closed, a lifecycle record. Static PDF snapshots capture point-in-time scan state; they do not track who was assigned the finding, what remediation was performed, when it was verified, or when the risk was formally closed. A living risk register provides exactly this audit trail. Scan frequency (B) increases data volume but does not add lifecycle tracking. Version-controlled PDFs (C) preserve scan history but still lack remediation provenance. Score-based filtering (D) would have excluded the IDOR if it scored below 7.0 and compresses exactly the audit evidence the regulator needs.

Why the others are wrong: ***B****, Daily scans show the vulnerability's presence over time but cannot demonstrate that remediation was taken, they are detection records, not remediation records.* ***C****, Version-controlled PDFs improve retrieval but the underlying PDFs still only capture scan state, not remediation actions, ownership, or closure verification.* ***D****, Restricting documentation by CVSS score creates a systematic gap, some high-business-impact vulnerabilities score below 7.0 (e.g., IDORs exposing regulated data may score 6.5 under strict vector analysis).*

17. A security team documents an XML injection vulnerability in a legacy internal application as "Low priority, internal only, limited user base." Three months later, the application is integrated into a customer-facing portal without a new security assessment. Which deficiency in the original risk documentation most directly contributed to this governance failure?

● A. The documentation lacked a scope and context statement specifying the conditions under which the rating was valid, it assumed a static deployment context, making the rating obsolete once the application's exposure changed.

○ B. The team used qualitative risk ratings rather than quantitative CVSSv3 scores.

○ C. All vulnerabilities in legacy applications should be classified critical as a blanket precaution against future integration scenarios.

○ D. Risk documentation for internal applications should be classified confidential and withheld from integration teams to prevent security theater.

Correct answer: A

Why: Risk ratings are context-dependent, "internal only" is not an inherent property of the application, it is a deployment assumption. Professional risk documentation should explicitly state the scope and boundary conditions of the rating (e.g., "Risk rated Low under the assumption that this application remains internal, behind the corporate firewall, with no external-facing integration. Re-assessment required if deployment context changes."). Without this, integration teams have no signal that the risk rating may no longer apply. Qualitative vs quantitative rating format (B) did not cause the governance gap. Blanket critical ratings (C) degrade prioritization by removing meaningful signal. Withholding documentation (D) from integration teams is the opposite of good governance.

Why the others are wrong: ***B****, Whether ratings are qualitative or quantitative is a methodology preference; the gap was the absence of context boundaries, not the rating scale used.* ***C****, Blanket critical ratings create alert fatigue and eliminate the prioritization function of risk*

ratings, they do not substitute for context-aware documentation. ***D****, Sharing risk documentation with teams that handle or integrate the asset is a governance requirement, not a security risk in itself.*

18. A security engineer must document a server-side template injection (SSTI) vulnerability in a customer-facing reporting tool and present the risk to non-technical executives to secure remediation budget. Which documentation approach best serves this audience while maintaining technical accuracy?

○ A. Present the raw CVSSv3 vector string and score without further translation, as executives should rely on standardized industry metrics for decision-making.

○ B. Describe the vulnerability using full OWASP nomenclature and exploitation technique details so executives can appreciate the precise technical severity.

● C. Translate technical findings into business impact language, estimating potential data exposure scope, regulatory penalty exposure, and reputational consequences, while linking to full technical documentation for security staff, and including a cost comparison between remediation effort and estimated breach costs.

○ D. Characterize the finding as "a minor software bug" pending patch availability to avoid alarming executives before a fix is ready.

Correct answer: C

Why: Effective risk communication to non-technical decision-makers requires translating technical findings into business terms: how many customer records are at risk, what regulatory fines could apply (e.g., GDPR, CCPA), what reputational damage could result, and how remediation cost compares to breach cost. This framing enables executives to make informed budget decisions. Raw CVSSv3 vectors (A) are meaningful to security professionals, not to executives approving budgets. Full OWASP exploitation detail (B) is similarly inaccessible and does not support a funding decision. Deliberately understating a critical vulnerability (D) is a form of misrepresentation that exposes the organization to greater harm if the issue is exploited while awaiting a downplayed patch.

Why the others are wrong: ***A****, CVSSv3 vectors encode technical exploitability metrics; non-technical executives cannot translate a vector string into a budget decision without business-context translation.* ***B****, Technical exploitation detail may increase comprehension among security staff but typically does not help a CFO or COO understand why a budget allocation is warranted.* ***D****, Understating vulnerability severity to avoid alarming stakeholders deprives decision-makers of accurate risk information and may constitute a failure of professional responsibility.*